

PKR Banking Institution of Canada

Cybersecurity Incident Response Playbook

Section 1: Data Breach

Document Revision Final

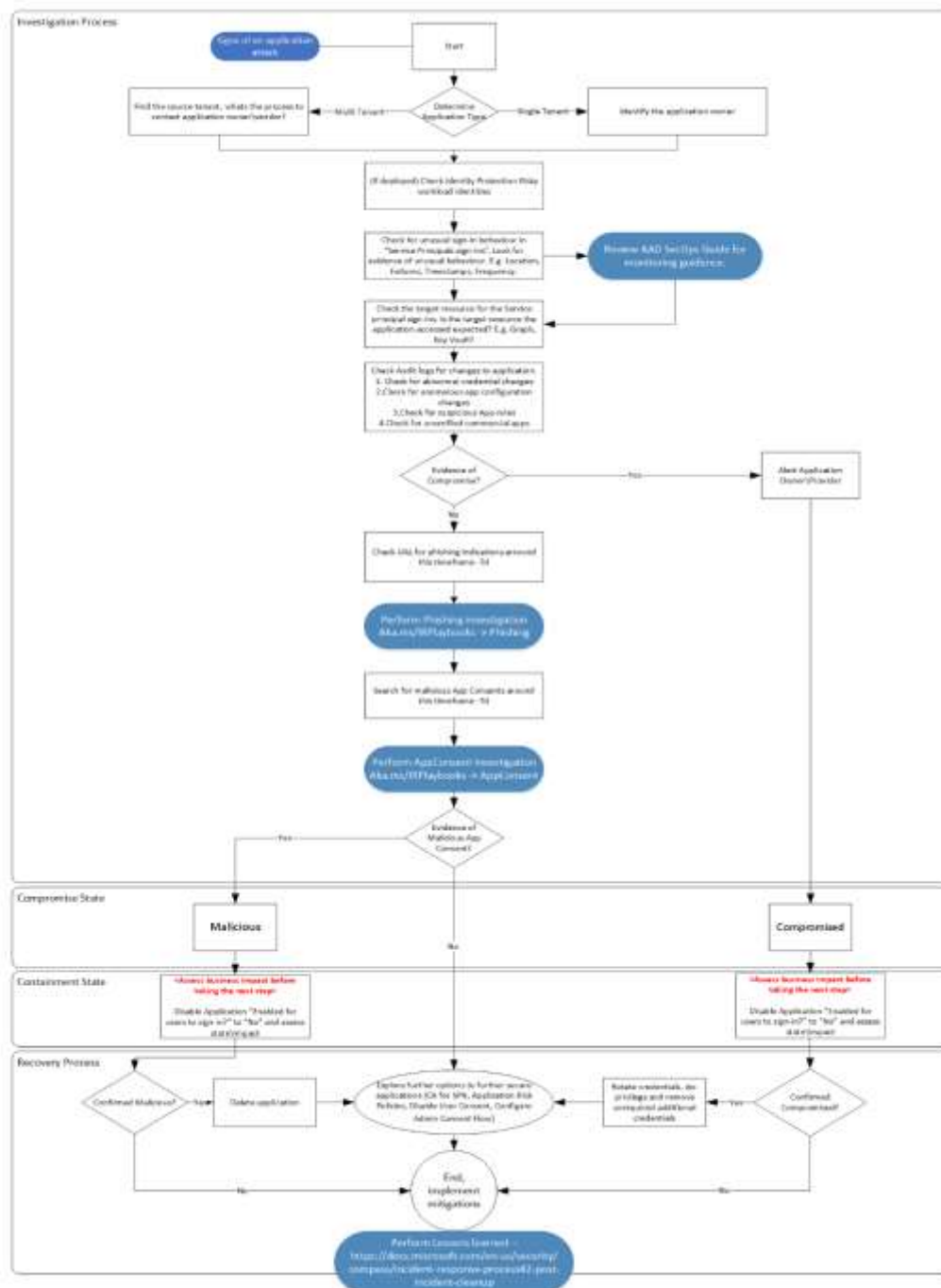
Date of Issue: September 19, 2025

Process/Procedure Owner: Joelle Waugh

Table of Contents

Introduction.....	4
Detection and Analysis.....	5
Classification	5
Information Gathering (Level 1 Response)	5
Information Gathering (Level 2 Response)	6
Information Gathering (Level 3 Response)	6
Escalation Decisions	6
Mitigation and Containment	7
Pre-Approved Communication Templates	8
Business Continuity	10
Recovery and Return to Normal Operation	10

Workflow



Appendix 1

.....11

References

12

Introduction

A data breach is a security event that occurs when unauthorized parties gain access to sensitive or confidential information. Sensitive and confidential information includes personal, corporate, and highly protected data that is not supposed to be public (Kaspersky, 2025). It becomes a data breach when that information is shared or seen without authorization. A data breach can also be a cyber attack, meaning a threat actor steals, destroys, disables, or gains unauthorized access (Kosin, 2025).

Data breaches can be performed externally by threat actors, individuals trying to commit a criminal offence, such as a cyberattack. They can also occur internally with a company's employees, and there could be a technological issue caused by outdated software or a failure to secure systems correctly.

Here are some terms and examples of what constitutes a data breach:

- **An Innocent Insider:** An employee who innocently makes a mistake that can be deemed a data breach (Kaspersky, 2025). For example, an employee mistakenly sends the wrong login credentials to another employee.
- **An insider threat:** A disgruntled employee who was laid off, terminated, or is angry at the company, causes a data breach to harm an individual or the company as revenge (Kaspersky, 2025). For example, an angry employee who hears about the upcoming layoffs decides to sell the company's intellectual property to competitors.
- **Lost or Stolen Company Devices:** Unencrypted PKR devices, such as laptops, mobile phones, and USB drives, without proper protection, can be easily read, used, and published by the individual who gains access to the lost or stolen devices (Kaspersky, 2025).
- **Hackers:** malicious threat actors who prepare various attacks to gain unauthorized access to data to sell or perform other attacks, such as information gathering, ransom attacks, and network attacks. This would meet the degree of a cyberattack; however, a hacker of this nature could also gather information from an individual (Kosinski, 2025).

The most common ways that data breaches occur are:

- **User Behaviour:** This is often underrated, but employees and users can give away information to the wrong individuals due to unconscious errors.
- **Phishing:** These emails are designed as social engineering attacks that trick users into clicking on malicious links or providing sensitive data. The attacker pretends to be a legitimate source; in other words, it is a scam (Kaspersky, 2025).
- **Brute-force attack:** An attacker uses technical tools to gain user credentials (Kaspersky, 2025).
- **Malware:** Some hackers may leave specific malicious software that performs various tasks, such as using SQL injections to gather information or zero-day attacks.

It is important to note that not all data breaches are cyberattacks. The incident responder must identify the different levels of data breaches and take the appropriate actions before deeming an incident a cyberattack.

Detection and Analysis

Data breach detection can vary and be complex. Due to the nature of data breaches, it is crucial to practice analysing any anomalies, which are indications of a compromise that may occur. The NIST framework encourages continuous monitoring of networks and services, the physical environment, personnel activity, technology usage, external service providers, and computing hardware and software (NIST, 2024).

Some of these included using Microsoft Office 365 for phishing emails and alerts, performing routine checks on equipment and software updates, ensuring the SIEM is updated and monitored, and configuring it to alert IT and Cybersecurity professionals of unusual events. The SIEM used to investigate emails is Microsoft Defender: emails and attack story, to check logins, and Splunk is used to monitor user logins.

Classification

Data breaches are common and can cause potential long-term damage to a company's reputation. When determining the severity and classification of a data breach, follow the guidelines below to decide the appropriate level:

- **Minor:** An internal isolated event that only involves one or more employees within the company. The data breach was made in error.
- **Moderate:** External or internal parties (threat actors, employees) seek data but do not successfully retrieve the data to sell or publish. In addition, these parties can only access data that does not compromise the company's reputation; therefore, no sensitive, highly protected, or confidential data was compromised.
- **Major:** Full data breach of sensitive, highly protected, or confidential data was compromised, sold, and published. This can damage the reputation of the company and require immediate attention.

Information Gathering (Level 1 Response)

When gathering information to classify the data breach at the helpdesk or IT first responders' level, the following questions should be investigated before responding:

- Who is involved in this data breach? Is this an internal, non-legally binding data breach? Is it an unknown party involved (such as a customer or threat actor)?
- What devices are involved in this data breach? Was it a lost or stolen mobile device, computer hardware, or software issue?
- Where was the starting point of the data breach? Did it occur through a phishing email? Was it an unidentified malware? Was it an attack on our networks or website?
- Does the phishing email have any malicious links? If so, what is the nature of the link, where does it lead, and what does it ask for? Who is the target? Was it a scam? What was it advertising and why?
- Does the Malware have specific tasks? Did it exploit a vulnerability? What was its entry point?



Information Gathering (Level 2 Response)

A security analyst will gather information at this level. From the information received from Helpdesk professionals or first tech respondents, the guidelines should be followed below:

- Does this meet the threshold of a moderate classification?
- Was this an external threat actor who performed the attack? What were their motives? How did it happen? Why did it happen?
- How can we improve our systems to prevent a similar attack? Where are the vulnerabilities and gaps in our security architecture?

Information Gathering (Level 3 Response)

A Senior Security Analyst or manager will gather at this level. From the information received from the prior levels, the guidelines should be followed below:

- Is this situation significant enough to be deemed major? Does the attack put customers at risk? Does the attack put staff at risk or both?
- What are the next steps in notifying the public? Who are the legal and governmental entities that need to be notified?
- Do lawyers need to be involved, and how?
- How does this impact the Bank financially? What are the services that impact customers?
- How much data has been compromised?

Escalation Decisions

Depending on the event's classification, follow the escalation guidelines below for continuity and documentation purposes. Regardless of the classification, all events should be documented.

- **Minor:** Any event within this category that poses an immediate risk to the company must follow the information gathering level 1 response and /or 2. A comprehensive report should be written about the event. In addition, the internal parties involved need to redo cybersecurity training and/ or speak with an IT team member regarding their actions.
- **Moderate:** Any event in this category should immediately be escalated to IT management. In a moderate situation, appropriate actions must be carried out to address system vulnerabilities immediately so that they do not escalate to a major classification event. In addition, a relevant department, such as HR, should be involved if it involves a current employee.
- **Major:** Any event in this category is considered serious and needs to be escalated to IT management immediately. In this case, all IT Management and the incident response team will respond to the event and address the needs appropriately. Once customers' data has been compromised and breached, it is essential to notify the Canadian Centre for Cyber Security of Canada and the Information and Privacy Commissioner of Ontario, followed by PIPEDA and any necessary law enforcement. Seek out the bank's legal team.

Refer to Appendix 1 for a workflow process.

Mitigation and Containment

Based on the classification, follow the recovery process. Refer to Appendix 1 for a workflow process.

Classification	Event	Recovery
Minor	Internal: Staff share another person's information with the wrong individual. A phishing email that caused no harm to the company.	Contain, change passwords, and delete information. Go through cybersecurity training and protocols. Contain and ensure the identified phishing email is deleted from all staff inboxes.
Moderate	There was an alert of suspicious activity from an external actor doing multiple logins; however, the attempts were unsuccessful. An insider threat was known before any significant damage was caused.	Investigate origins and secure any vulnerabilities. Practice safe and secure cybersecurity practices. Update passwords with stronger rules. Find out why the insider threat happened and look for ways to mitigate it. Speak with other departments about employee experience.
Major	Any event that breaches the confidentiality of banks' data, such as personal data, staff logins, and sensitive company data.	Enter immediate recovery mode. Locate the breach. Restore backup information so that some services can be operational. Notify all leadership to call a meeting to discuss next steps. All data loss should be reported to Canadian Centre for Cybersecurity (CCCS). All privacy breaches must be reported to Ontario's Information and Privacy Commissioner (IPC).



Pre-Approved Communication Templates

Email Communication for Minor Issues

User or Staff reported phishing

Dear [valued customer, staff(name)]

Thank you for your email.

The message you have forwarded is indeed a phishing attempt.

Please delete the email from your inbox. You require no further action at this time.

Below is a list of things to look for when identifying a phishing email:

[Staff (Only: 1) All outside emails will have a disclaimer that does not originate inside the company banner.]

[Customer (Only: 1) All PKR emails are sent to customers with a non-reply function]

2) All promotional PKR emails are sent with a verified signature, and all links will lead you to our online banking home page.

3) When in doubt, email PKR services at pkrservices@pkrbic.com

If you have any questions or concerns, please let us know.

Sincerely,

PKR IT Department

Employee reports a data breach concern

Dear [Staff name],

Thank you for your email. The PKR IT department will investigate the matter immediately.

You will hear from our representative regarding the next steps.

If you have any further questions or concerns, please let us know.

Sincerely,

PKR IT Department

Email Communication for Moderate Tickets

Dear [staff],

Please be advised that we have experienced an incident that requires a system update. This system will be temporarily unavailable during [mention start date and end time].

Sincerely,

PKR IT Department

For Customer Online Services, please add a banner on the online services to notify customers.

These services will be unavailable during these times [insert time]. For more information, [include link to PKR Tech Services Website.]

Email Communication for High Tickets

Subject Line: ATTN: Important Security Notice

Dear [Staff, Management, CEO, (company-wide email for region)],

On [date] at [time], a significant security breach has impacted some of our services. Due to PKR, we will contact each department with the required security steps. PKR will be conducted at a hot site backup to ensure the smooth operation of our services. However, it will take some time to get to everything back to normal

Due to the major incident, online banking will be suspended to avoid further complications until the problem is resolved.

During this time, as we work on a backup system, we ask that everyone be diligent when clicking on links from emails outside the company. Please look for the warning banner on each email as shown below:

WARNING!!! This email is from an outside sender. Respond with caution and be vigilant when clicking on links.

PKR IT will keep you updated until the situation is resolved. If you have further questions and concerns, please contact your manager or PKR at pkrservices@pkrbic.com or call us at (671)676-6767 ext. 1111 for any immediate issues.

Thank you for your patience,

PKR IT Department

Business Continuity

Business continuity is essential to society and our reputation; therefore, determining where the affected sites are and what they are is important. All sites should use the hot site backup method. Depending on the classification, the customer should go to a local banking branch instead of using online banking. Online banking will be treated as warm sites for partial connectivity (Agorye, 2024) and to reduce risk, as the IT team ensures a complete network clean-up. PKR values customers' data and has invested in Hot Sites and backup sites. This means that the equipment and hardware will rollover to back up smoothly, network connectivity will be consistent, and data will be up to date. This allows the IT team to clean up and the bank fully operational because of the minimal downtime (Agorye, 2024).

Backups will help branches run smoothly and allow staff to serve customers. Though hackers may be able to hack customers' accounts and funds, having backup information can help investigators determine the exact times and dates when the data occurred. Additionally, PKR can claim insurance for damages as PKR has followed the proper protocol.

As a final institution, PKR must have cyber resilience against attacks. When a major attack occurs, the scope must entail all departments, including customer services, corporate functions, and branches. This needs to happen as quickly as possible. Training programs will be conducted monthly to ensure that PKR reduces data breaches. Business impact analysis will occur monthly unless there has been a recent attack. Exercises and testing for the IT department will occur monthly to ensure everyone is prepared to deal with an attack and recovery. Monitoring and reporting are continuous and crucial to maintain an effective cybersecurity program (Flecher, 2025).

Recovery and Return to Normal Operation

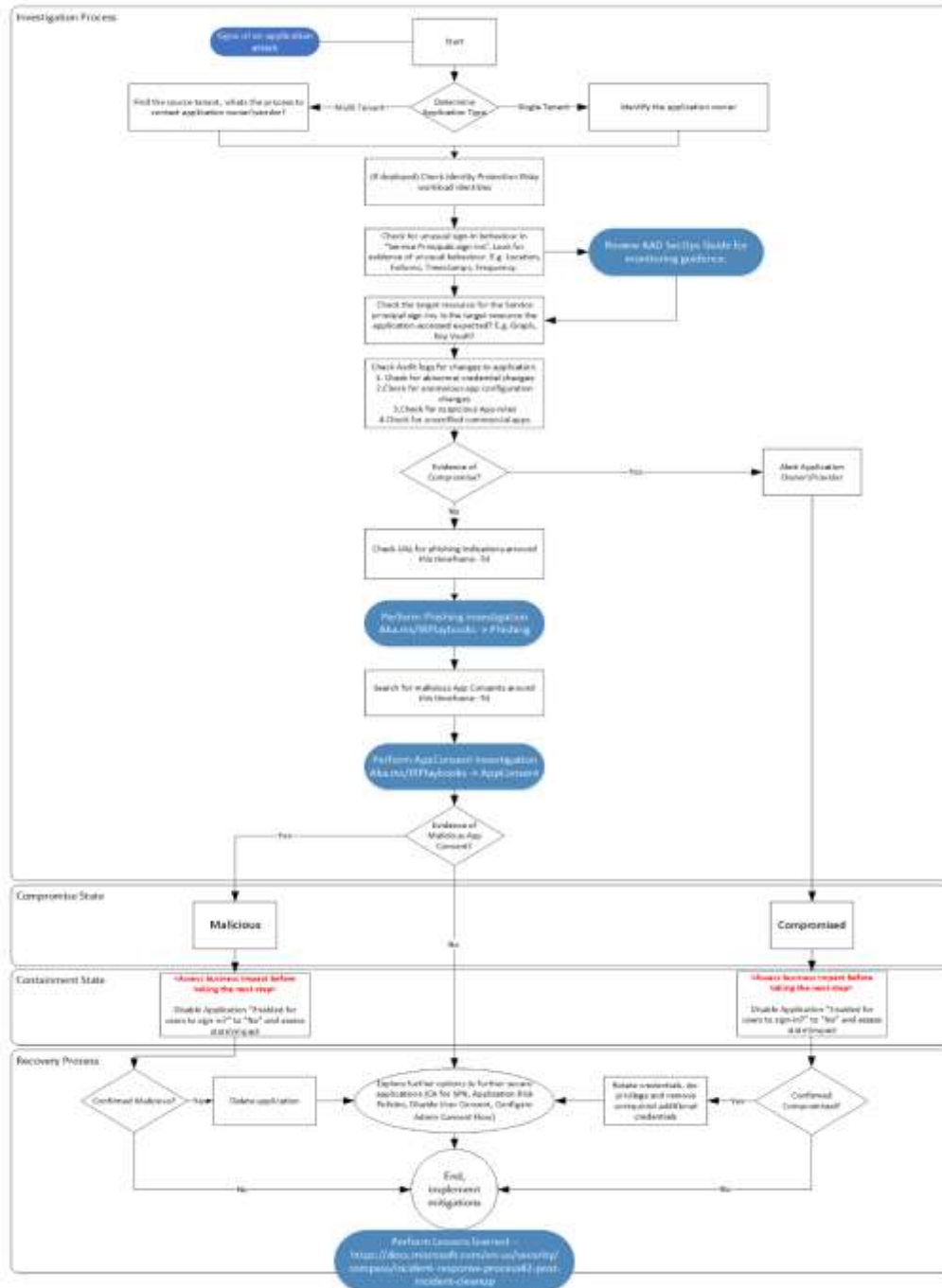
Recovery from a partial shutdown would take 2-3 business days for everyone to return to work. This would require the full cooperation of all PKR Banking Institutions of Canada staff to follow the directives of the IT department, as new updates would be initiated. A new protocol and training would be required before PKR can be fully operational. After 2-3 business days, have a lesson learned session with all parties involved in the recovery process. Be sure to look for vulnerabilities that must be patched in the system. Examine what caused them, and why they happened. Propose and implement solutions, and have refreshed cybersecurity training for all departments, including customers.

Refer to Appendix 1 for a process workflow that will lead to recovery.



Appendix 1

Workflow



References

- Agorye, J. (2024, February 6). *Hot Site, Warm Site, and Cold Site Represent Different Levels of Backup for Disaster Recovery*. Verpex. <https://verpex.com/blog/website-tips/hot-site-warm-site-and-cold-site-represent-different-levels-of-backup-for-disaster-recovery>
- CyberAlberta. (2024 March 13). *Data breach playbook*. <https://cyberalberta.ca/system/files/data-breach-playbook.pdf>
- Fochler, S. (2025 February 27). *What is Business Continuity for Financial Institutions?*. Ncontracts. <https://www.ncontracts.com/nsight-blog/what-is-business-continuity-for-financial-institutions>
- Kaspersky. (2025). *What is data breach? How to prevent data leaks*. Kaspersky. <https://www.kaspersky.com/resource-center/definitions/data-breach>
- Kosinski, M. (2025). *What is a data breach?* IBM. <https://www.ibm.com/think/topics/data-breach>
- NIST. (n.d.). *The NIST Cybersecurity Framework (CSF) 2.0*. <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- Microsoft Security. (2024, November 1). *How to investigate email messages in Microsoft Defender for Office 365*. YouTube. <https://www.youtube.com/watch?v=5hA7VfaMvqs>
- Microsoft Security. (2023, April 26). *Microsoft 365 Defender: Attack Story*. YouTube. <https://www.youtube.com/watch?v=ohJEIMoXrbw>
- Microsoft Learn. (Appendix 1) (2025, March 12). *Compromised and malicious applications investigation*. <https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-compromised-malicious-app>

